

WEEK 2, DISCOVER — AUG 19, 2026

AI Ethics, PDPA & IT Law

Law and ethics are not a later slide. They become **requirements** you put in the backlog next week — and they are on the midterm.

Examinable · Midterm + Final

In-class case today

CLO1 Ethics · CLO2 Knowledge

Dr. Prasara Jakkaew, ADT MFU

TODAY • 3 HOURS

What we cover

- 01 Recap: your company, interviews, no production code yet
- 02 Why AI fails: hallucination, bias, no owner
- 03 Thai AI ethics (ETDA) — six principles you can test
- 04 PDPA · Computer Crime Act §26 · e-Transactions Act
- 05 Turn law into requirements (CupLog example)
- 06 Mini workshop: analyse an AI failure → write **your** company's rule.md

You are still not writing production code

Last week

Company + Charter

Name, five roles, three pains, one direction, interview plan.

This week

Compliant requirements

Ethics and Thai law become backlog items — not a disclaimer at the end.

Next week

Agents → backlog

CLAUDE.md, sub-agents, GitHub. You add the legal reqs you write today.

Gate W5

Sep 9

Proposal + backlog + design + **compliance**. Unlock BUILD only if you pass.

Guardrail 4 is still in force: **PDPA-safe** — consent for any real data; no sensitive data without a plan.

THE ONE SENTENCE

A human is always responsible. AI does not get a free pass — and neither does your company.

COURSE AI POLICY, 2569

WHY THIS WEEK, NOT LATER

If it is not a requirement, it will not ship

TOO LATE

Bolt ethics on at the end

- Privacy notice copy-pasted from another app
- No consent, no delete, no log — “we’ll add it”
- AI answers users with no owner and no fallback

THIS COURSE

Write it as a requirement now

- Every legal duty becomes an LR (legal requirement)
- LRs go into the W3 backlog as Must items
- W5 Gate checks compliance, not just diagrams

Three failure modes you must name

01 Hallucination

Confident and wrong

The model invents a policy, a fact, or a quote. A user acts on it. Someone gets hurt or loses money.

02 Bias

Unfair by design of data

Past data encodes past unfairness. The system repeats it at scale — hiring, credit, waitlists.

03 No owner

Nobody is accountable

“The AI did it” is not a defence. If there is no human fallback, there is no engineering.

On the exam: name the failure, name who is harmed, name the control (review, log, consent, fallback).

Air Canada chatbot — hallucination + liability

Moffatt v. Air Canada BC Civil Resolution Tribunal, 2024 BCCRT 149

WHAT HAPPENED

A passenger asked about a bereavement fare. The bot said he could apply for the discount **after** booking — the real policy required requesting it **before** travel.

THE DEFENCE

Air Canada argued the chatbot was a “separate legal entity” and the passenger should have checked the real policy page it linked to.

THE RULING

Rejected. Air Canada had to pay **CAD \$812.02** in damages and tribunal fees.

IN THE TRIBUNAL’S WORDS

“It makes no difference whether the information comes from a static page or a chatbot.” — Christopher Rivers, tribunal member

SE LESSON

If your product answers users with AI, you own the answer. Need: human fallback, source of truth, log of what was said.

Amazon recruiting tool — bias in training data

WHAT THEY BUILT

Score CVs with AI

- Trained on 10 years of past hires
- Past hires were mostly men in tech roles
- The model learned to penalise “women’s” signals (e.g. women’s colleges)
- Rated CVs 1–5 stars; favoured male-coded verbs like “executed”, “captured”

WHAT IT TEACHES

Bias is a requirements bug

- Accuracy on old data ≠ fairness on new people
- You need a fairness check before you ship ranking/AI
- If you cannot explain a score, do not use it to reject people

Amazon scrapped it (Reuters, Oct 2018). Amazon’s line: “never used by recruiters to evaluate candidates” — but recruiters did see its picks. Your company is smaller — you can still ship unfair AI if you never look.

A clinic waitlist model that “just worked”

HealthAI fictional clinic triage — used in this course

PRODUCT

Ranks who sees the doctor next from past appointment notes and a symptom chatbot.

FAILURE

Older patients wait longer. Symptom text is stored forever. Staff cannot see **why** someone was deprioritised.

5 WHYS (SHORT)

1 Why late? Model score. 2 Why low score? Past no-shows. 3 Why no-shows? Transport, not “lazy”. 4 Why no review? “AI is accurate”. 5 Why notes kept? Nobody wrote a retention rule.

BROKEN DUTIES

Fairness (bias) · **transparency** (no explanation) · **PDPA** (health data, no consent, no delete) · **accountability** (no human override)

This is the in-class case shape: failure → who is harmed → which principle/law → what requirement would have blocked it.

Six principles — write them as tests

1

Competitiveness & sustainability

Build AI to genuinely benefit people/society long-term — not just because you can.

2

Laws, ethics & standards

Human-centered by design. A human stays the decision-maker — AI never alone decides someone's fate.

3

Transparency & accountability

Explainable, predictable, auditable. A named role owns the impact — not "the model".

4

Security & privacy

Protects data and systems from threats. A human can still intervene to control risk.

5

Fairness

Diverse, not monopolised or biased. The outcome must be provably fair, including to groups you didn't test.

6

Reliability

Accurate and reproducible. Hallucinations are defects — log them and give users a feedback channel.

Memorise these six for the midterm. W10 goes deeper on governance; today is the foundation.

Four acts you'll meet this course

PDPA

Personal Data Protection Act

Consent, purpose, access / correct / delete. Extra care for sensitive data (health, biometrics).

CCA §26

Computer Crime Act

Keep computer traffic / access logs for **at least 90 days**. Who, when, from where.

ETA §9 / 26 / 28

Electronic Transactions Act

§9 e-signature test. §26 presumed-reliable signature. §28 certification / CA duties. Your consent checkbox is an agreement — record it.

Cyber Act

Cybersecurity Act

Protects the country's critical systems (banking, telecom, energy...) from cyber threats. Context only — not covered in depth here.

Also examinable later (W10): copyright of AI output, liability, contracts. The first three become LR1–LR3 today.

If you store a person, you have duties

DUTY	IN YOUR PRODUCT, THAT MEANS
Lawful basis	Ask consent before you store name, phone, email, photos. Do not hide it in a 12-page policy.
Purpose limit	Use data only for the reason you stated. Interview notes ≠ marketing list.
Minimise	Collect the least you need. “Store everything in case” fails PDPA.
Access / correct / delete	A user can see their data, fix it, and ask you to erase it. That is a feature, not an email to the TA.
Sensitive data	Health, religion, biometrics, student grades used to profile — do not collect without an explicit plan. Guardrail 4.

YOUR INTERVIEWS THIS MONTH

User research is already a PDPA activity

ALLOWED

- Ask consent out loud before you record or take notes
- Store role + pain + quote — not full ID if you do not need it
- Keep the evidence log on the team drive with access limited to the company
- Delete recordings when the quote is captured, if that was the deal

NOT ALLOWED

- Secret recordings
- Pasting raw interview transcripts into a public LLM
- Inventing users with AI (also an AI-policy fail)
- Health / ID card numbers “just in case”

Keep an access log for ≥ 90 days

If people log into your system, you must be able to say **who accessed what, and when** — and keep that trail at least 90 days.

Who

Actor

User id or role — not necessarily a real name on the screen.

When

Timestamp

Login, important writes, exports. Timezone stated.

What

Action

Login / save / export / delete. Enough to investigate later.

This is why CupLog's backlog item B5 is Must, not Could: consent + access log is part of the core workflow, not a nice-to-have.

A tick-box is a legal act if you can prove it

§9

E-signature test

Signing can be electronic if it (1) identifies the signer + shows intent, and (2) uses a method reliable enough for that transaction's risk/value.

§26

Presumed-reliable e-signature

Meet 4 tests (linked to owner, owner-only control, tamper-evident) and the law treats it as reliable automatically.

§28

CA / PKI

Know that certificate authorities exist for stronger identity. You do not need to build a CA. You do need to know the word for the exam.

Exam trap: “the user clicked OK” with no timestamp, no version of the text they saw, no user id — that fails §9's own reliability test.

Law → three legal requirements

CupLog .docs/01-requirements/01-spec/...-legal-pdpa.md

LR1 PDPA

If we store a barista's name or email, we get consent first; they can view and delete their data.

LR2 CCA §26

Keep an access log (who logged in, when) for at least **90 days**.

LR3 ETA

The consent checkbox is an agreement — record **who, when, which version of the text**.

BACKLOG

B5 Must — Consent + access log. Same sprint as “record a cupping”. Compliance is in the core workflow.

Full pipeline: CupLog-Worked-Example. Copy the **structure**, not the coffee product.

THE PATTERN FOR EVERY COMPANY

Failure → principle → law → requirement

IF THIS GOES WRONG	PRINCIPLE / LAW	WRITE THIS KIND OF REQUIREMENT
AI invents an answer a user trusts	Reliability · accountability	Show sources or “I don’t know”; human can override; log the reply
Ranking hurts one group	Fairness (ETDA 5)	No silent ranking of people without a review rule
You store names / chats	PDPA	Consent + access + delete; minimise fields
Login exists	CCA §26	Access log ≥ 90 days
User ticks “I agree”	ETA §9 / 26	Store who / when / text version
AI or server is down	Security & privacy (ETDA 4)	A human can step in; core workflow still works without the model

MINI WORKSHOP • IN-CLASS CASE (PASS / FAIL)

45 minutes • write your rule.md

- 1 **Pick YOUR product** — the one in your Company Charter, not a case company
- 2 For each law today — **PDPA • Computer Crime Act §26 • Electronic Transactions Act §9/26/28** — write 1–2 sentences: what it is + what it requires
- 3 Under each law, write **as many concrete rules as you can** for an AI coding agent building your product — more is better, not just one per law
- 4 Write rules as **direct commands to the AI** — "If the system stores ____, it must ____" — not prose explaining the law to a human
- 5 Submit `rule.md` text on Google Classroom / photo before you leave. This is the in-class case tick.

Output template

rule.md {Company name} — Legal & Compliance Rules for AI Agents

{Company} — Legal & Compliance Rules (rule.md)

Read this before writing any code that touches user data or user actions.

PDPA (Personal Data Protection Act)

What it is: ____

What it requires: consent · purpose limit · minimise · access/correct/delete · sensitive data

Rules for the agent (write as many as you can):

- If the system stores ____, it must ____
- If the system uses ____, it must ____

Computer Crime Act §26

What it is: ____

What it requires: keep an access/traffic log ≥90 days, tied to a real user

Rules for the agent:

- If the system has ____, it must log ____
- ____

Electronic Transactions Act §9 / 26 / 28

What it is: ____

What it requires: valid e-signature test (§9) · presumed-reliable signature (§26) · CA duties (§28)

Rules for the agent:

- If the user clicks "I agree" on ____, the system must record ____
- ____

BEFORE W3 (AUG 26)

Your actions

01

Keep interviewing

Evidence log growing toward ≥ 15 . Consent first. No classmates. No AI personas.

02

Finish your rule.md

Turn today's draft into a real `rule.md` (repo root, next to where CLAUDE.md will live) — a Google Doc is fine until GitHub next week.

03

Bring raw requirements

Pains + quotes + your rule.md. W3 we turn them into a backlog with agents and skills.

Still no production code. DISCOVER ends at the User Validation Gate (W5, Sep 9).

MIDTERM HINT • DO NOT WAIT UNTIL SEPTEMBER

You will be asked to apply, not recite

Likely

Given a short failure

Name the ETDA principle, the Act/section, and write one testable requirement.

Numbers

90 days

Computer Crime Act §26 retention. Consent is not “90 days” — logs are.

Rights

Access / correct / delete

PDPA rights are product features. “We’ll email the admin” is a weak answer.

Liability

Air Canada pattern

Your company owns what the bot says. “The AI did it” fails.

NEXT CLASS

See you in Week 3

Aug 26 — Requirements → Product Backlog with AI Agents & Skills. Bring your Charter, interview notes, and your `rule.md` from today.

Deliverable today: in-class case page

1305493, SE Case Studies, 1/2569

CCA §26 — full text (verbatim)

มาตรา 26 พ.ร.บ.ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. 2550

วรรค 1

ผู้ให้บริการต้องเก็บรักษาข้อมูลจราจรทางคอมพิวเตอร์ไว้ไม่น้อยกว่า **90 วัน** นับแต่วันที่ข้อมูลเข้าสู่ระบบ พนักงานเจ้าหน้าที่สั่งขยายได้ถึง **2 ปี** เฉพาะรายและเฉพาะคราว

วรรค 2

ต้องเก็บข้อมูลที่ระบุตัวผู้ให้บริการได้ตั้งแต่เริ่มให้บริการ และเก็บต่ออีกไม่น้อยกว่า **90 วัน** หลังเลิกให้บริการ

วรรค 3

ผู้ให้บริการประเภทใด อย่างไร เมื่อใด — เป็นไปตามประกาศรัฐมนตรีกระทรวงดิจิทัลฯ ในราชกิจจานุเบกษา

โทษ

ผู้ให้บริการที่ไม่ปฏิบัติตามมาตรานี้ → ปรับไม่เกิน **500,000 บาท**

แหล่งที่มา: ข้อความทางการจาก ETDA (Computer Crimes Act B.E. 2550 and B.E. 2560) · ประกาศราชกิจจานุเบกษา 18 มิ.ย. 2550 เล่ม 124 ตอนที่ 27 ก · มีผลบังคับใช้ 30 วันถัดมา · ไม่ถูกแก้ไขโดยฉบับที่ 2 พ.ศ. 2560

APPENDIX • BACKUP SLIDE, NOT PART OF THE 180-MIN FLOW

CCA §26 — 6 key points

01

"ผู้ให้บริการ" กว้างมาก

ม.3: ผู้ให้เข้าถึงเน็ต + ผู้ให้บริการเก็บข้อมูลเพื่อประโยชน์คนอื่น — แอปที่มี login ก็เข้าข่าย ไม่ใช่แค่ ISP

02

Log ≠ เนื้อหา

"ข้อมูลจราจร" คือ metadata (ใคร/เมื่อไหร่/จากไหน) ไม่ใช่บังคับเก็บข้อความ/เนื้อหาแชท

03

ออกแบบตั้งแต่ sprint แรก

Log retention เป็น non-functional requirement ต้องอยู่ใน backlog ตั้งแต่ต้น ไม่ใช่แก้ทีหลัง

04

ม.26 ≠ ม.27 — คนละโทษ

ม.26 (ไม่เก็บ log) → ปรับ 500,000 · ม.27 (ขัดคำสั่งศาล/จนท. ตาม ม.18/20/21) → ปรับ 200,000 + รายวันไม่เกิน 5,000/วัน

05

ปิดบัญชีแล้วยังต้องเก็บ

ผู้ใช้เลิกใช้บริการ/ลบบัญชี → ยังต้องเก็บข้อมูลระบุตัวตนต่ออีก 90 วัน (วรรค 2 — จุดที่มักถูกมองข้าม)

06

ใช้บังคับมาตั้งแต่ 2550

ประกาศราชกิจจานุเบกษา 18 มิ.ย. 2550 มีผลบังคับ 30 วันถัดมา — ไม่ใช่กฎหมายใหม่ ไม่ถูกแก้ไขโดยฉบับที่ 2/2560

Does my system count as a "ผู้ให้บริการ"?

#	SCENARIO	WHY IT'S §26 / WHAT TO DO
1	เว็บอีคอมเมิร์ซที่มีระบบ login ลูกค้า <i>E-commerce site with customer login</i>	Log user_id, IP, เวลา login/logout ≥90 วัน <i>Log user_id, IP, login/logout time — keep ≥90 days</i>
2	Chatbot ที่เรียก API ผ่าน backend ของทีมเอง <i>A chatbot that calls an API through your own backend</i>	Log ว่า request ไหน เวลาใด มาจาก user ไหน — ไม่จำเป็นต้องเก็บเนื้อหาแชท <i>Log which request, when, from which user — not required to store the chat content itself</i>
3	แอปจองคิว / จองห้อง <i>Queue-booking / room-booking app</i>	ทุกการจอง/ยกเลิกต้องมี log timestamp + ผู้ใช้ ≥90 วัน <i>Every booking/cancellation needs a timestamp + user logged, kept ≥90 days</i>
4	แอป Delivery ที่มี tracking คนขับ <i>Delivery app with driver tracking</i>	Log การเชื่อมต่อ/ยืนยันตัวตน ไม่จำเป็นต้องเก็บพิกัด GPS ทุกจุด (นั่นคือ PDPA minimisation) <i>Log connection/authentication events — not required to store every GPS point (that's PDPA minimisation instead)</i>
5	ฟอรัม/โซเชียลที่โพสต์แบบนามแฝง <i>Forum/social app with pseudonymous posting</i>	Backend ต้องผูก log กับ account จริงเสมอ เมื่อพนักงานเจ้าหน้าที่ขอตรวจสอบ <i>The backend must always tie logs to the real account, in case officials request them</i>
6	SaaS ที่ทีม host ข้อมูลให้ธุรกิจอื่น <i>SaaS where your team hosts data for another business</i>	เข้าข่าย ม.3(2) "ผู้ให้บริการเก็บรักษาข้อมูลเพื่อประโยชน์บุคคลอื่น" ชัดเจนที่สุด <i>Squarely matches §3(2)'s "service provider storing data for someone else's benefit"</i>
7	Wifi ฟรีของร้านกาแฟ (แบบ CupLog) <i>Free café Wi-Fi (like CupLog)</i>	ร้านกลายเป็น "ผู้ให้บริการ" ทันทีที่ปล่อย Wifi ให้ลูกค้า <i>The shop becomes a "service provider" the moment it offers Wi-Fi to customers</i>
8	Internal tool ให้พนักงานภายในเข้าถึงเครือข่าย <i>Internal tool giving staff network access</i>	ยังเข้าข่ายผู้ให้บริการประเภทองค์กร ไม่ใช่แค่ public-facing app <i>Still counts as an organizational service provider — not just public-facing apps</i>
9	MVP ตั้ง auto-delete log ทุก 7 วัน เพื่อประหยัด storage <i>MVP auto-deletes logs every 7 days to save storage</i>	ตัวอย่างการทำผิด — ต่ำกว่าขั้นต่ำ 90 วัน แม้เจตนาจะแค่ optimize cost Violation example — falls short of the 90-day minimum, even if the intent was just cost optimization
10	ทีมพึ่ง log ของ Firebase/Google OAuth อย่างเดียว <i>Team relies only on Firebase/Google OAuth's own logs</i>	ความเข้าใจผิดที่พบบ่อย — เจ้าของแอปต้อง log การใช้งาน "ในระบบตัวเอง" เอง ไม่ใช่พึ่งผู้ให้บริการ auth ภายนอกทั้งหมด Common misconception — the app owner must log activity "inside their own system" too, not rely entirely on an external auth provider

Ref: พ.ร.บ.ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. 2550 ม.3, 26, 27 (ข้อความทางการจาก ETDA) · ประกาศกระทรวงดิจิทัลเพื่อเศรษฐกิจและสังคม เรื่องหลักเกณฑ์การเก็บรักษาข้อมูลจราจรทาง

คอมพิวเตอร์ของผู้ให้บริการ พ.ศ. 2564 — full URLs in the teaching-script appendix.

ETA §9 — full text (verbatim)

มาตรา 9 พ.ร.บ.ว่าด้วยธุรกรรมทางอิเล็กทรอนิกส์ พ.ศ. 2544

หลัก

ในกรณีที่กฎหมายกำหนดให้ต้องมีการลงลายมือชื่อ ให้ถือว่าได้มีการลงลายมือชื่อแล้วถ้า (1) ใช้วิธีการที่ระบุตัวเจ้าของลายมือชื่อได้ และแสดงเจตนาของเจ้าของเกี่ยวกับข้อความนั้นได้ และ (2) ใช้วิธีการที่เชื่อถือได้เหมาะสมกับวัตถุประสงค์ หรือวิธีอื่นที่ยืนยันตัวเจ้าของและเจตนาได้ด้วยตัวเองหรือประกอบพยานหลักฐานอื่น

ปัจจัยความน่าเชื่อถือ

(1) ความมั่นคง/รัดกุมของวิธีระบุตัวบุคคล ระดับความปลอดภัย (2) ลักษณะ ประเภท ขนาด จำนวนครั้ง มูลค่าของธุรกรรม (3) ความรัดกุมของระบบติดต่อสื่อสาร

ขยายผล

ใช้กับการประทับตราของนิติบุคคลด้วยวิธีอิเล็กทรอนิกส์โดยอนุโลมด้วย

โทษ

ไม่มี — เป็นกฎ "รับรองผลทางกฎหมาย" ไม่ใช่ข้อห้าม หากไม่ผ่านเกณฑ์ แต่ไม่นับเป็นลายมือชื่อที่ถูกต้อง ไม่ใช่ความผิดที่มีโทษปรับ/จำคุก

แหล่งที่มา: ข้อความทางการจากสำนักงานคณะกรรมการกฤษฎีกา (ผ่าน mdes.go.th) · ประกาศราชกิจจานุเบกษา 4 ต.ค. 2544 (เล่ม 118 ตอนที่ 112 ก) · มีผลบังคับใช้ 180 วันถัดมา ($\approx$ 3 มิ.ย. 2545) · ปรับปรุงด้วยคำล่าสุด โดยฉบับที่ 3 พ.ศ. 2562

APPENDIX • BACKUP SLIDE, NOT PART OF THE 180-MIN FLOW

ETA §9 — 6 key points

01

Technology-neutral

ไม่ระบุเทคโนโลยีเฉพาะ ใช้ได้กับ OTP/password/biometric/PKI ทุกแบบ ขอแค่ผ่านเกณฑ์ 2 ข้อ

02

เกณฑ์หลัก 2 ข้อ

(1) ระบุตัวเจ้าของ + แสดงเจตนาได้ (2) ใช้วิธีที่ "น่าเชื่อถือ" เหมาะกับสถานการณ์

03

"น่าเชื่อถือ" ไม่ใช่ค่าคงที่

ธุรกรรมยิ่งเสี่ยง/มูลค่าสูง ยิ่งต้องใช้วิธียืนยันตัวตนที่รัดกุมกว่า — เกณฑ์เดียวใช้กับทุกฟีเจอร์ไม่ได้

04

ไม่มีบทลงโทษในตัวเอง

เป็นกฎรับรองผล ไม่ใช่ข้อห้าม — ไม่ผ่านเกณฑ์ = ไม่นับเป็นลายมือชื่อ ไม่ใช่ความผิดอาญา

05

ศาลไทยตีความกว้าง

ฎีกา 8089/2556: รหัส ATM = ลายมือชื่อ · ฎีกา 6757/2560: ข้อความ Facebook ที่ปรากฏชื่อผู้ส่ง = ลงลายมือชื่อตาม ม.9 แล้ว

06

ครอบคลุมตราของนิติบุคคลด้วย

วรรคสุดท้ายขยายเกณฑ์เดียวกันนี้ไปใช้กับการประทับตรานิติบุคคลทางอิเล็กทรอนิกส์

Does my "confirm" button count as a signature under §9?

#	SCENARIO	§9 READ
1	นักศึกษาพิมพ์ชื่อท้ายอีเมลยืนยันส่งงาน <i>A student types their name at the end of an email confirming submission</i>	เข้าข่าย ม.9 ถ้าระบุตัวตน+แสดงเจตนายอมรับได้ชัดเจน <i>Counts under §9 if it clearly identifies the person and shows their intent</i>
2	กดปุ่ม "ยอมรับเงื่อนไข" พร้อม log user_id+timestamp <i>Clicking "Accept Terms" with user_id + timestamp logged</i>	น่าเชื่อถือพอสำหรับธุรกรรมความเสี่ยงต่ำ (สมัครสมาชิกฟรี) <i>Reliable enough for a low-risk transaction (free sign-up)</i>
3	สัญญากู้ยืมเงินมูลค่าสูงใช้แค่ tick-box ธรรมดา <i>A high-value loan agreement uses just a plain tick-box</i>	อาจไม่ผ่าน "น่าเชื่อถือ" เพราะมูลค่า/ความเสี่ยงสูง ต้องใช้วิธีรัดกุมกว่า <i>May fail the "reliable" test — high value/risk needs a stronger method</i>
4	OTP ผ่าน SMS ยืนยันธุรกรรม <i>SMS OTP confirming a transaction</i>	ตัวอย่าง e-signature มาตรฐานที่ผ่านเกณฑ์ ม.9 ได้ทั่วไป <i>A standard e-signature example that generally passes the §9 test</i>
5	บัตรกดเงินสด + รหัสส่วนตัวที่ ATM <i>ATM card + PIN at a cash machine</i>	ศาลฎีกาตัดสินแล้วว่านับเป็นลายมือชื่อตาม ม.9 (คำพิพากษาฎีกา 8089/2556) <i>The Supreme Court has ruled this counts as a signature under §9 (Dika 8089/2556)</i>
6	ส่งข้อความ Facebook ยกหนี้ให้ มีชื่อผู้ส่งปรากฏ <i>A Facebook message forgiving a debt, showing the sender's name</i>	ศาลฎีกาตัดสินว่านับเป็นลายมือชื่อตาม ม.9 แล้ว (ฎีกา 6757/2560) <i>The Supreme Court ruled this already counts as a signature under §9 (Dika 6757/2560)</i>
7	Email link คลิกยืนยันโดยไม่มี log ผู้คลิกจริง <i>An email confirmation link clicked with no log of who actually clicked it</i>	เสี่ยงไม่ผ่าน "ระบุตัวเจ้าของ" ตาม ม.9(1) <i>Risks failing the "identify the owner" test under §9(1)</i>
8	Fingerprint scan ก่อนอนุมัติคำสั่งซื้อในแอป <i>Fingerprint scan before approving a purchase in the app</i>	ตัวอย่าง biometric signature ที่ ETDA ยกเป็นตัวอย่าง e-signature <i>A biometric signature example ETDA itself cites as an e-signature</i>
9	ทีมออกแบบระบบเซ็นสัญญาจ้างงานออนไลน์ให้ลูกค้า <i>Your team designs an online employment-contract e-signing system for a client</i>	ต้องเลือกความเข้มงวดของวิธียืนยันตัวตนตาม "ขนาด/มูลค่าธุรกรรม" ไม่ใช่ใช้มาตรฐานเดียวทุกฟีเจอร์ <i>Must scale identity-verification strength to the "size/value of the transaction" — one standard doesn't fit every feature</i>
10	ระบบนับแค่ "กดปุ่ม OK" ไม่มี timestamp/เวอร์ชันข้อความ/user id <i>The system counts just "clicking OK," with no timestamp / message version / user id</i>	กับดักข้อสอบ — ไม่นับเป็นหลักฐานลายมือชื่อที่มีน้ำหนักตาม ม.9 Exam trap — this doesn't count as solid signature evidence under §9

Ref: พ.ร.บ.ว่าด้วยธุรกรรมทางอิเล็กทรอนิกส์ พ.ศ. 2544 ม.9 (ข้อความทางการจากสำนักงานคณะกรรมการ
กฤษฎีกา) · คำพิพากษาศาลฎีกา 8089/2556, 6757/2560 (อ้างอิงจากสไลด์ฝึกอบรม ETDA) — full URLs in
the teaching-script appendix.

ETA §28 — full text (verbatim, condensed)

มาตรา 28 พ.ร.บ.ว่าด้วยธุรกรรมทางอิเล็กทรอนิกส์ พ.ศ. 2544 — หน้าที่ "ผู้ให้บริการออกใบรับรอง"

(1) – (2)

ปฏิบัติตามแนวนโยบาย/แนวปฏิบัติที่ตนประกาศไว้ + ใช้ความระมัดระวังให้ข้อมูลในใบรับรองถูกต้องครบถ้วนตลอดอายุใบรับรอง

(3)

เปิดช่องให้ผู้กรณีตรวจสอบได้ว่า ใครเป็นผู้ออกใบรับรอง / เจ้าของลายมือชื่อควบคุมกุญแจจริงหรือไม่ / กุญแจยังใช้ได้ขณะออกใบรับรอง

(4)

เปิดช่องตรวจสอบวิธีระบุตัวเจ้าของ, ข้อจำกัดวัตถุประสงค์, ความสมบูรณ์ของกุญแจ, ขอบเขตความรับผิดชอบ, ช่องทางแจ้งเหตุ, และบริการเพิกถอนใบรับรองที่ทันการ

(5) – (6)

ต้องเพิกถอนใบรับรองได้ทันทีเมื่อได้รับแจ้ง + ใช้ระบบ วิธีการ และบุคลากรที่ "เชื่อถือได้" ในการให้บริการทั้งหมด

โทษ

ไม่มีโทษเฉพาะใน ม.28 — แต่ถ้าประกอบ**ธุรกิจ**ออกใบรับรองโดยไม่แจ้ง/ขึ้นทะเบียน/ขอใบอนุญาตตาม ม.32–34 (ตามระดับความเสี่ยง) มีโทษจำคุก 1–3 ปี หรือปรับ 100,000–300,000 บาท ตาม ม.44/44-1/45

แหล่งที่มา: ข้อความทางการจากสำนักงานคณะกรรมการกฤษฎีกา (ผ่าน mdes.go.th) · ม.28 ไม่ถูกแก้ไขโดยฉบับที่ 2–4 (2551–2562)

ETA §28 — 6 key points

01

ผูกกับ "CA" เท่านั้น

ใช้กับผู้ทำหน้าที่ออกใบรับรอง (Certification Service Provider) ไม่ใช่ผู้ใช้ทั่วไปหรือเจ้าของลายมือชื่อ (นั่นคือ ม.27)

02

6 หน้าที่หลัก

ทำตามนโยบายตัวเอง, รักษาความถูกต้อง, เปิดตรวจสอบข้อเท็จจริง, เปิดตรวจสอบข้อจำกัด/เพิกถอน, รับแจ้งเหตุ, ใช้ระบบที่เชื่อถือได้

03

ไม่มีบทลงโทษเฉพาะ

การไม่ทำตามหน้าที่ในมาตรานี้ไม่มีค่าปรับ/จำคุกโดยตรงๆ แต่กระทบความน่าเชื่อถือทางกฎหมายของใบรับรองที่ออก

04

โทษจริงอยู่ที่ขึ้นใบอนุญาตธุรกิจ

ประกอบธุรกิจ CA โดยไม่แจ้ง/ขึ้นทะเบียน/ขอใบอนุญาตตาม ม.32-34 → จำคุก 1-3 ปี หรือปรับ 100,000-300,000 บาท (ม.44/44-1/45)

05

ทีมนักศึกษาแทบไม่ต้องทำเอง

ใช้ CA ที่มีอยู่แล้ว (Thai Digital ID, ธนาकार, DBD e-Certificate) แทนสร้างระบบ CA เอง หลีกเลียงภาระ ม.28+32-34 ทั้งหมด

06

คู่กรณีก็มีหน้าที่ตรวจสอบ

ม.29-30: ปัจจัยความน่าเชื่อถือของระบบ CA + คู่กรณีต้องตรวจสอบตามสมควรด้วย ไม่ใช่แค่ CA ฝ่ายเดียว

Is my team accidentally running a Certificate Authority?

#	SCENARIO	§28 READ
1	ทีมสร้างระบบออก "ใบรับรองดิจิทัล" ให้บริษัทอื่นใช้เซ็นเอกสาร <i>Your team builds a system that issues "digital certificates" for other companies to sign documents</i>	กลายเป็น "ผู้ให้บริการออกใบรับรอง" ต้องทำตาม ม.28 แทนที่ ไม่ใช่แค่ feature ธรรมดา <i>You've become a "certificate-issuing service" and must follow §28 immediately — this isn't just an ordinary feature</i>
2	ใช้ third-party CA ที่มีอยู่แล้ว (Thai Digital ID, GDCA) <i>Using an existing third-party CA (Thai Digital ID, GDCA)</i>	วิธีที่ถูกสำหรับ MVP นักศึกษา หลีกเลี่ยงภาระ ม.28 ทั้งหมด <i>The right approach for a student MVP — avoids all of §28's burden</i>
3	ระบบไม่เปิดเผยว่าใครเป็นผู้ออกใบรับรอง <i>The system doesn't disclose who issued the certificate</i>	ไม่ปฏิบัติตามหน้าที่เปิดช่องตรวจสอบตาม ม.28(3)(ก) <i>Fails the duty to allow verification under §28(3)(a)</i>
4	ไม่มีช่องทางตรวจว่าใบรับรองถูกเพิกถอน/หมดอายุหรือยัง <i>No way to check whether a certificate has been revoked or expired</i>	ขาด "revocation check" ตาม ม.28(4)(จ) <i>Missing the "revocation check" required under §28(4)(f)</i>
5	เจ้าของลายมือชื่อแจ้งกุญแจส่วนตัวรั่วไหล แต่ระบบไม่มีช่องรับแจ้ง <i>A signature owner reports a leaked private key, but the system has no way to receive that report</i>	ต้องมีช่องทางรับแจ้ง+เพิกถอนทันที ตาม ม.28(5) คู่กับหน้าที่แจ้งของเจ้าของตาม ม.27(2) <i>Must have a report-and-immediate-revoke channel under §28(5), paired with the owner's own duty to report under §27(2)</i>
6	ปล่อยข้อมูลผู้ถือใบรับรองล้าสมัยไม่อัปเดต <i>Letting certificate-holder information go stale without updating it</i>	ไม่รักษาความถูกต้อง/ครบถ้วนตลอดอายุใบรับรองตาม ม.28(2) <i>Fails to keep the information accurate/complete for the certificate's full life, under §28(2)</i>
7	เซิร์ฟเวอร์ CA ไม่มีมาตรฐานความปลอดภัยเพียงพอ (ไม่มี HSM เก็บกุญแจ) <i>The CA server lacks adequate security standards (no HSM for key storage)</i>	เสี่ยงไม่ผ่านเกณฑ์ "ระบบ/บุคลากรที่เชื่อถือได้" ตาม ม.28(6) <i>Risks failing the "reliable systems/personnel" test under §28(6)</i>
8	อยากทำ CA เป็นธุรกิจหลัก ไม่ใช่แค่ feature ภายในแอป <i>Wanting to run a CA as your core business, not just an in-app feature</i>	ต้องตรวจ ม.32-34 เรื่องแจ้งขึ้นทะเบียน/ใบอนุญาตด้วย — ม.28 อย่างเดียวไม่พอ <i>You must also check §§32–34 on notification/registration/licensing — §28 alone isn't enough</i>
9	ธนาคาร/DBD ออก e-Certificate ผ่านระบบทางการ <i>A bank/DBD issuing e-Certificates through an official system</i>	ตัวอย่างจริงในตลาดที่ปฏิบัติตาม ม.28 อยู่แล้ว <i>A real, already-compliant example already operating in the market under §28</i>

#	SCENARIO	§28 READ
10	ทำแค่ self-signed certificate ใช้ภายในระบบปิด ของตัวเอง <i>Just using a self-signed certificate inside your own closed team system</i>	ไม่เข้าข่าย "ให้บริการ" ตาม ม.28 เพราะไม่ได้ออกให้บุคคลภายนอก <i>Doesn't count as "providing a service" under §28 since it's not issued to outside parties</i>

Ref: พ.ร.บ.ว่าด้วยธุรกรรมทางอิเล็กทรอนิกส์ พ.ศ. 2544 ม.28, 29, 30, 32-34, 44-45 (ข้อความทางการจาก
สำนักงานคณะกรรมการกฤษฎีกา) — full URLs in the teaching-script appendix.